

SOC ANALYST LEVEL 1

Lecture 8: Phishing Email Analysis

Practical Security Analysis & Initial Incident
Response

Author: [Nader Anam](#) | Duration: 3
Hours

LECTURE OBJECTIVES

- ✓ Understand the meaning of Phishing Email
- ✓ Learn why Phishing is a top initial access vector
- ✓ Analyze suspicious email elements & headers
- ✓ Examine Sender, Reply-To, & Attachments
- ✓ Understand SPF, DKIM, and DMARC
- ✓ Determine User Action & Severity
- ✓ Decide on Password Resets & Blocking
- ✓ Write a Phishing Analysis Report
- ✓ Take Action: Close / Investigate / Escalate

WHY IS THIS LECTURE CRITICAL?



Credential Theft

One email can steal passwords and compromise entire identities.



Malware Execution

Initial delivery for ransomware, spyware, and C2 agents.



Network Entry

The gateway to Lateral Movement and Data Exfiltration.

WHAT IS PHISHING?

Phishing is an attack based on **deception**. The attacker tricks the victim into:

- 🖱️ Clicking a malicious link
- 📄 Entering sensitive credentials
- ⬇️ Opening infected attachments
- 🛡️ Sharing MFA or OTP codes

Primary Goal: Credential Theft or Malware Delivery.



PHISHING EMAIL

PHISHING BEYOND EMAIL



Smishing

Phishing via SMS, WhatsApp, or Telegram messages.



Vishing

Voice-based phishing using social engineering.



Quishing

Using QR Codes to redirect users to fake login pages.

This lecture focuses on **Email Phishing** as it is the most common in SOC environments.

COMMON TYPES OF PHISHING

Type	Description
Generic Phishing	General message sent to a large number of users.
Spear Phishing	Targeted at a specific person, role, or department.
Whaling	High-profile targets like CEOs, CFOs, or Managers.
Credential Phishing	Explicitly designed to steal login information.
Malware Delivery	Involves links or attachments that download malware.
BEC	Business Email Compromise (impersonating partners or execs).

WHY DOES PHISHING SUCCEED?

Phishing exploits the **Human Element** through psychology:

- ⚡ **Urgency:** "Account will be suspended in 1 hour."
- 💰 **Enticement:** "Your salary update is ready."
- 👤 **Authority:** Impersonating IT Support or HR.
- ❓ **Curiosity:** "Review this private document."



| THE SOC ANALYST'S REAL DUTY

It's not just about saying "The email is fake." Your duty is to:

-  Extract and analyze IOCs (Links, Hashes, IPs)
-  Determine if the user interacted (User Action)
-  Assess the blast radius (How many others got it?)
-  Recommend containment (Block URL, Reset PW)
-  Document the findings in a professional report
-  Escalate if a breach is confirmed

| QUESTIONS TO ASK EVERY TIME

Who is the Sender?

Official domain? Gmail?
Mismatched Display Name?

Where does it lead?

Does the URL match the actual
destination behind the text?

What was the Action?

Did the user click? Download?
Enter a password?

KEY ELEMENTS TO INSPECT

Element	What to analyze?
Sender / From	Email address vs Display Name alignment.
Reply-To	Does the reply go to a different, external domain?
Subject	Look for urgency, threats, or enticing topics.
Links (URLs)	The hidden destination, typosquatting, redirects.
Attachments	File type (.docm, .exe, .iso) and Macro requests.
Headers	SPF/DKIM/DMARC results and Return-Path.

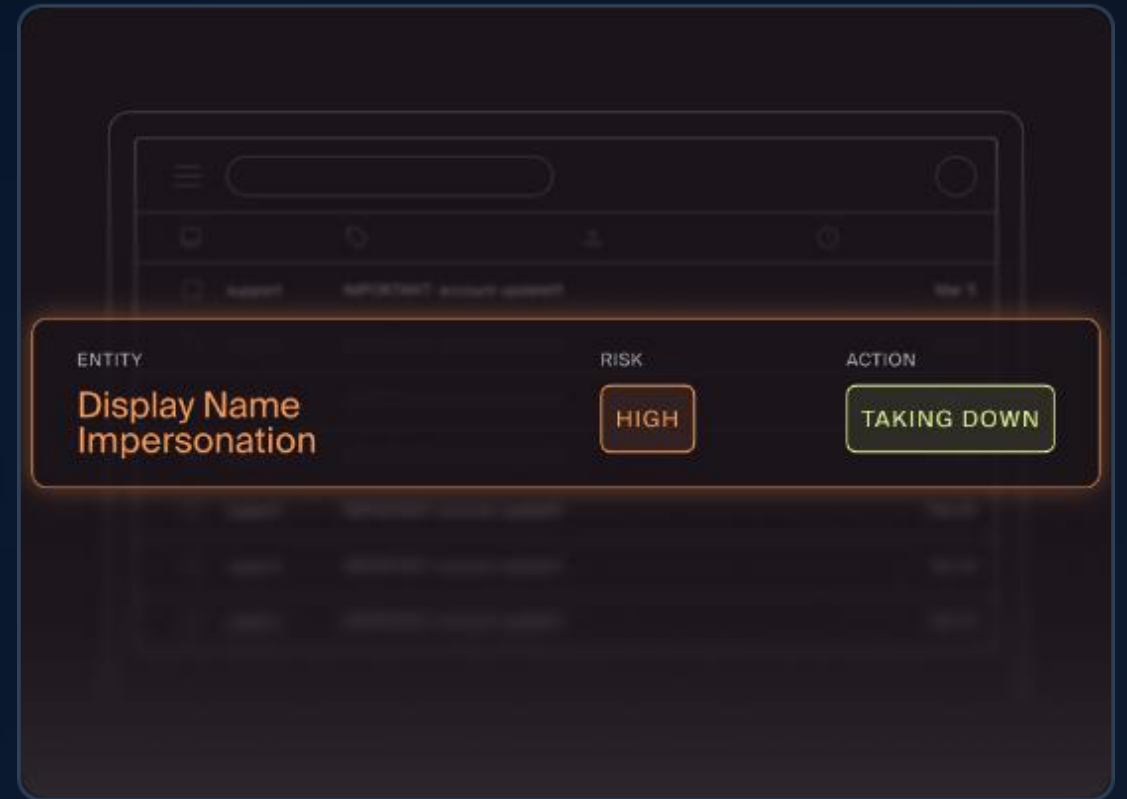
| DISPLAY NAME VS. EMAIL ADDRESS

Attackers use **Deceptive Display Names** to bypass quick glances.

Display Name: Microsoft Support

Real Address: support-alert@gmail.com

An Analyst **MUST** always inspect the **Full Address**.



EXAMPLE: DOMAIN IMPERSONATION

Spot the difference in this malicious From field:

```
Microsoft Security 0ft-login.example>
```

- ! Replaced 'o' with '0'
- ! Added '-login' to the official domain
- ! Using a '.example' TLD instead of '.com'
- ! Verdict: **Phishing Attempt**

| SENDER ANALYSIS CHECKLIST

- 🔍 Is the domain official and correctly spelled?
- 🔍 Does it use a public provider (Gmail/Yahoo) for business
- 🔍 mail?
Is this sender known or expected by the recipient?
- 🔍 Are there visible signs of spoofing or lookalike techniques?
- 🔍 Does the Return-Path match the From address domain?

EXAMINING THE 'REPLY-TO' FIELD

A critical indicator: The 'From' looks legitimate, but the 'Reply-To' redirects to an attacker-controlled mailbox.

From: HR Department

Reply-To: hr.helpdesk.2026@gmail.com

If the user replies, the communication bypasses corporate filters and goes directly to the **Attacker**.

ANALYZING THE SUBJECT LINE

Subject lines are designed to trigger **Action without Thinking**.

Urgent: Password Verification Required

Suspicious Login Detected - Final Warning

Overdue Invoice: Payment Needed Now

Your mailbox is 99% full - Fix Now

MFA Verification Needed - Immediate
Action

Salary Update: Review your 2026 Bonus

| INSPECTING THE EMAIL BODY

- 👁 Look for spelling/grammatical errors
- 👁 Identify generic greetings ("Dear User")
- 👁 Requests for credentials or sensitive data
- 👁 Buttons hiding suspicious URLs
- 👁 Instructions to "Enable Content" or "Macros"
- 👁 Note: High-end Phishing can be error-free!

EXAMINING HYPERLINKS (URLS)

Never trust the visible text. Always inspect the **Destination URL**.

Text Displayed: <https://portal.company.com/login>

Actual Link: <https://security-login-check-update.example/login>

Check for typosquatting

Analyze URL shorteners

Look for multiple redirects

| THE HTTPS FALLACY



HTTPS ≠ Safe

Many users think **HTTPS** means a site is safe. This is **WRONG**.

HTTPS only means the connection is **encrypted**.

Attackers can (and do) get SSL certificates for their phishing sites easily.

Always verify the **Domain**, not just the padlock icon.

COMMON MALICIOUS URL PATTERNS

`hxxps://microsoft-security-verify.example/login` (Added words)

`hxxps://office365.reset-password.example/` (Subdomain spoof)

`hxxps://accounts-google-verify.example/` (Impersonation)

`hxxps://secure-doc-review.example/auth` (Generic urgency)

These are designed to look "official" enough to trick a busy user.

MALICIOUS ATTACHMENT TYPES

Type	Risk Reason
.exe / .scr	Direct Executables (Malware)
.js / .vbs	Scripts used for staging attacks
.docm / .xlsm	Office files with Malicious Macros
.zip / .rar	Used to hide/obfuscate payloads



| OFFICE FILES & MACROS

Malicious Office files often display an "Enable Content" or "Enable Macros" prompt.

.docx / .xlsx

Usually safe (no macro support).

.docm / .xlsm

Macro-enabled. High risk.

Execution

Macros can launch PowerShell or CMD commands.

Never enable macros on a file from an external or suspicious source!

EXAMPLE: PHISHING VIA MACRO

Subject: Salary Update Required

Attachment: salary_update_2026.xlsm

Message: "Please open the file and enable content to view your updated salary structure."

The **Subject** (Salary) drives curiosity, the **Type** (.xlsm) provides the weapon, and the **Message** instructs the user to disarm their own security (Enable Content).

| THE "USER ACTION" FACTOR

The severity of a phishing alert is defined by **What the User Did**. Always ask:



Clicked?

Did they click the link? Check Proxy/DNS logs.



Submitted?

Did they enter a password on the fake page?



Executed?

Did they open the file and Enable Macros?

USER ACTION & SEVERITY MATRIX

Action	Severity	Primary Risk
Email Delivered (No Interaction)	Low	None (Pre-incident)
Link Clicked (No Submission)	Medium	IP Tracking / Recon
Credentials Submitted	High	Account Compromise
Macro Enabled / File Executed	Critical	Endpoint Infection / Malware
MFA Prompt Approved	Critical	Bypassed Security Barrier

| WHEN TO REQUEST A PASSWORD RESET?

Do not reset passwords for every spam email. Only recommend it if:



User confirmed entering their password on a suspicious site



A suspicious login occurred shortly after the phishing email



Unexpected MFA prompts were observed



Suspicious "Forwarding Rules" appeared in the mailbox

| THE DANGER OF MAILBOX RULES

Attackers create **Forwarding Rules** after a successful breach to maintain persistence.

Rule Name: "Archived"

Action: Forward all incoming mail to **attacker@external-domain.example**

Action: Move original mail to "Deleted Items"

This allows the attacker to spy on communications and intercept password resets silently.



EMAIL HEADER ANALYSIS

Peering into the technical metadata of an email message.

ESSENTIAL HEADER FIELDS

From: Visible sender address

Reply-To: Destination for replies

Return-Path: Address for bounce messages

Received: The path of servers taken

X-Originating-IP: Sender's IP address

Authentication-Results: SPF, DKIM, DMARC status

Message-ID: Unique identifier for the mail

| THE 'RETURN-PATH' INDICATOR

The **Return-Path** (or Envelope Sender) is where delivery failures are sent. It often reveals the true sender when the 'From' is spoofed.

From: support@microsoft.com

Return-Path: random-user@strange-vps-server.example

A mismatch here is a strong indicator of **Spoofing**.

| TRACING WITH 'RECEIVED' HEADERS

'Received' headers document every server that handled the email. They should be read from **Bottom to Top**.

Bottom Header: The very first server (the true origin).

Analyzing IPs: Does the Originating IP belong to a known legitimate server or a residential IP in a foreign country?

This is critical for detecting advanced impersonation that passes initial filters.

| SPF: SENDER POLICY FRAMEWORK

Concept: Does this server have permission to send mail for this domain?

SPF Pass

Server is authorized.

SPF Fail

Unauthorized server detected.

SPF SoftFail

Questionable source; monitor.

SPF verifies the **IP Address** against a DNS directory of allowed senders.

DKIM: DOMAINKEYS IDENTIFIED MAIL

Concept: Is the message digitally signed and untampered?

-  Provides a **Digital Signature** in the header.
-  Proves the email content hasn't been modified in transit.
-  Uses Public/Private key cryptography.

If **DKIM Fail** is observed, the integrity of the message is compromised.

DMARC: THE POLICY ENFORCER

Concept: Ties SPF and DKIM together and provides a policy on what to do if they fail.

p=none

Monitor only; deliver anyway.

p=quarantine

Send failed mail to Spam/Junk.

p=reject

Block failed mail completely.

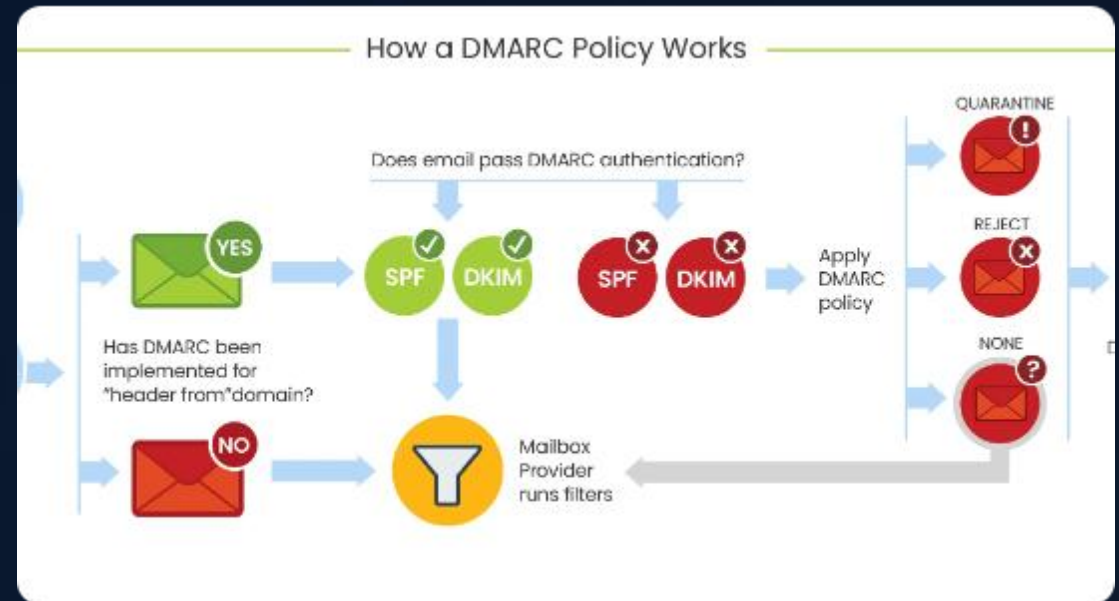
DMARC ensures the "From" domain **aligns** with the SPF/DKIM authenticated domains.

AUTHENTICATION IS NOT A SAFETY GUARANTEE

An email can have **SPF/DKIM/DMARC Pass** and still be malicious.

Why? The attacker owns the domain "**company-login-verify.example**" and set it up correctly with all authentication protocols.

Authentication says "This email is from [X domain]". It does NOT say "[X domain] is safe."



TOOLS FOR URL REPUTATION

VirusTotal

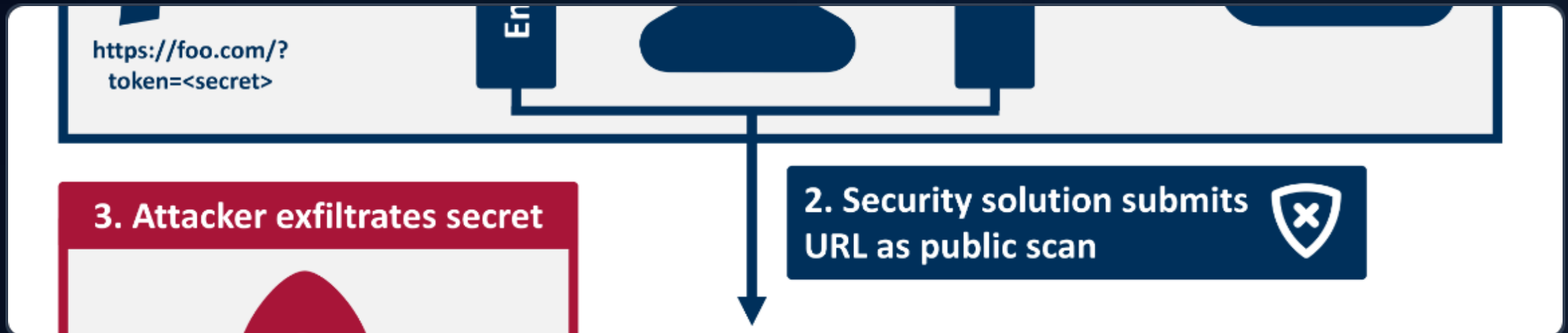
Aggregates many antivirus and URL scanners.

URLScan.io

Provides a screenshot and behavior analysis of a site without visiting it manually.

Cisco Talos

Checks domain age, categorization, and reputation history.



| ANALYZING ATTACHMENT HASHES

A Hash (e.g., [SHA256](#)) is the digital fingerprint of a file.



Check the hash on [VirusTotal](#) or [MalwareBazaar](#).



Has this file been seen in other phishing campaigns?



Does the hash trigger EDR alerts on other machines?

Note: Attackers slightly modify files to change their hashes; lack of a detection doesn't mean it's safe.

PHISHING INVESTIGATION SOURCES

To build a solid case, correlate data from:

-  Email Headers & Body
-  Email Gateway Logs
-  Proxy & DNS Logs (for clicks)
-  EDR & Endpoint Logs (for execution)
-  Authentication Logs (for logins)



SCENARIO 1: NO USER INTERACTION

Observation: Suspicious email received by user Ahmed. Indicators confirm it is phishing. However, logs show Ahmed **did not open** or click anything.

Severity: Low

Verdict: Likely Phishing (Containment Required)

Action: Delete/Quarantine email, block IOCs, no PW reset needed.

SCENARIO 2: USER CLICKED THE LINK

Observation: User Muna clicked the phishing link. Proxy logs confirm she visited the site, but she **did not enter** any credentials.

Severity: Medium

Verdict: Confirmed Phishing (Successful Click)

Action: Inspect for downloads, educate user, monitor account. PW reset optional but recommended as a precaution.

SCENARIO 3: CREDENTIAL THEFT

Observation: User entered password on a fake login page. 10 mins later, a login from a **New Country** succeeded.

Severity: High / Critical

Action: Immediate **Password Reset**, Revoke Sessions, check for Forwarding Rules.

Using Your Details

Stolen credentials can be used to shop, scam, or steal your identity. Always use strong, unique passwords and enable MFA.



SCENARIO 4: MALWARE EXECUTION

Observation: User opened .xlsm attachment and enabled macros. EDR alerts show **Excel launching PowerShell**.

Severity: CRITICAL

Action: Isolate Host, analyze PowerShell command, trigger Incident Response (IR).

Warning Alert **

77-220-4850:

ter access will be disabled to
work.

it has been infected with a
re. The following information is

o that our expert engineers
process over the phone to
within the next 5 minutes to
disabled or from any

77-220-4850

Security Warning:

** Microsoft Warning Al

ERROR # 268d3x8938(3)

Please call us immediate
Do not ignore this critica
If you close this page, yo
further damage to our n
Your computer has alert
Spyware and riskware. T

1.Facebook Logins
2.Credit Card Details
3.Email Account Logins
4.Photos stored on this c

Please call us within the
being disabled or from a

Toll Free: +1-877-2

☐ Prevent this page from

INDICATORS FOR ESCALATION

- ⚠ User submitted company credentials
- ⚠ Malicious Macros were enabled
- ⚠ Encoded PowerShell was executed
- ⚠ Suspicious file was downloaded
- ⚠ Login from a new/unusual country
- ⚠ New Mailbox Forwarding Rule created
- ⚠ Persistent C2 outbound connections
- ⚠ Sensitive user (C-Level/IT) targeted

| WHEN TO CLOSE THE PHISHING ALERT?

You can close the ticket as **Benign** if:

Verified Source

Email is from a confirmed vendor or internal source.

Safe Link

Link leads to a legitimate, safe business portal.

No Malice

Headers, body, and attachments show no malicious intent.

Always document **Evidence** for closure!

| WHEN TO ESCALATE THE ALERT?

Escalate to Tier 2 or Incident Response (IR) if:



Confirmed credential theft with account activity



Confirmed malware execution on a corporate host



Business Email Compromise (BEC) with financial risk



Large-scale campaign affecting dozens of users



Detection of Lateral Movement or C2 patterns

PHISHING ANALYSIS TEMPLATE



A structured approach to investigating every
alert.

| THE ANALYSIS REPORT BREAKDOWN

Header Data: Sender, Reply-To, Recipient, Time

Indicators: URLs, Attachment Hashes

Auth Status: SPF/DKIM/DMARC results

User Action: Detailed user interaction status

Severity: Risk assessment (Low/Med/High/Crit)

Verdict: Benign / Phishing / Malware

Actions: Containment and Remediation steps

Escalation: Yes/No

PRACTICAL CASE STUDY: USER AHMAD

A multi-vector phishing attack
investigation.

AHMAD CASE: OBSERVED INDICATORS

From: Payroll Department

Reply-To: payroll.verify2026@gmail.com

 Link: [hxxps://company-payroll-check.example/login](https://company-payroll-check.example/login)

 Attachment: payroll_update.xlsm

 User Ahmed: Clicked, Entered Password, Enabled
Macros

AHMAD CASE: TECHNICAL ANALYSIS

Execution

Excel launched encoded PowerShell - potential malware staging.

Network

Outbound connection to 91.200.10.5 every 60 seconds (Beaconing).

Compromise

Login from unknown country + Forwarding Rule created.

AHMAD CASE: RECOMMENDED ACTIONS

-  Immediate Password Reset
-  Revoke all sessions & tokens
-  Block malicious IP & URL
-  Isolate affected Endpoint
-  Remove Forwarding Rule
-  Escalate to Tier 2 / IR Team



"Ahmed fell victim to a combined Credential Theft & Malware attack. The presence of encoded PowerShell, C2 beaconing, and an unauthorized mailbox rule confirms a full host and account compromise."

SOC Case Final Summary

| AVOID THESE COMMON MISTAKES

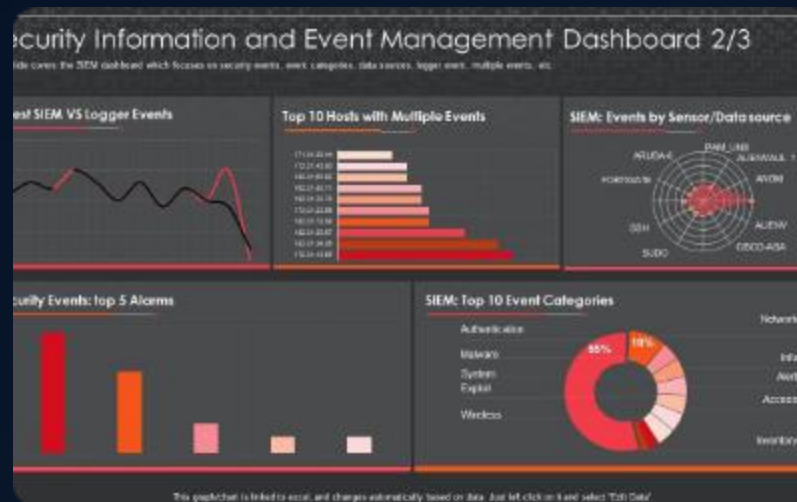
- ✗ Judging based on email "look" only
 - ✗ Ignoring the 'Reply-To' header
 - ✗ Assuming HTTPS = Safety
 - ✗ Skipping the User Action check
 - ✗ Running attachments on your PC
 - ✗ Resetting passwords for every spam
-

THE SOC GOLDEN RULE



"Don't just ask if the email is fake. Ask what the user did and what events followed. The real danger is the chain of events after delivery."

COMING UP NEXT...



Introduction to SIEM

Log Sources | Correlation Rules | Alert vs. Incident | Dashboard Analysis

IMAGE SOURCES



https://png.pngtree.com/png-vector/20230328/ourlarge/pngtree-phishing-email-with-hacker-illustration-and-virus-notification-vector-png-image_51005038.jpg

Source: [pngtree.com](https://png.pngtree.com)



<https://res.cloudinary.com/dq7c8oaav/image/upload/v1767009480/media/snptcxq2sewmvbg6jxf9.webp>

Source: www.craw.in



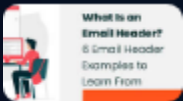
<https://prod-cms.doppel.com/sites/default/files/2026-03/Display-Name-Spoofing-1.png>

Source: www.doppel.com



<https://cdn.vectorstock.com/i/500p/53/76/spam-warning-circle-vector-64045376.jpg>

Source: www.vectorstock.com



<https://blog-cdn.engagebay.com/blog/wp-content/uploads/2024/02/email-header-examples.jpg>

Source: www.engagebay.com



<https://www.emailonacid.com/wp-content/uploads/2021/07/DMARC-Policy-Process.png>

Source: www.emailonacid.com

IMAGE SOURCES



https://cdn.prod.website-files.com/5f6498c074436c349716e747/6358304b4951324ae820a732_urlscan_mining_cover.png

Source: positive.security



https://unihackers.com/_next/image?url=%2Fblog%2Fday-in-the-life-soc-analyst%2Fhero.webp&w=1920&q=75&dpl=dpl_Bz1ZQjTrwVfh6FRbxffG1wj4xCD5

Source: unihackers.com



<https://caniphish.com/Supporting/Posters/identity-theft-poster.png>

Source: caniphish.com



<https://appuals.com/wp-content/uploads/2019/04/error-message-3.jpg>

Source: appuals.com



<https://images.template.net/163821/cyber-security-incident-report-template-jp5ls.jpg>

Source: www.template.net



https://www.slideteam.net/media/catalog/product/cache/1280x720/i/n/information_and_event_management_dashboard_siem_for_security_analysis_slide01.jpg

Source: www.slideteam.net
